

SOC DETECTION LAB

Commercial-Ready Product Requirements, Technical Architecture & Security Operations Blueprint

A production-inspired, self-contained SOC platform for detection engineering, incident investigation, threat hunting, response automation and audit-ready reporting.

Document Attribute	Value
Document Type	PRD + TRD + Architecture + Security Design + Implementation Roadmap
Product Name	SOC Detection Lab
Edition	Commercial-Ready Reference Product
Version	1.0
Status	Target Architecture / Build Specification
Primary Model	Single-tenant lab → deployable SOC platform
Deployment	Docker Compose for lab; Kubernetes-ready target architecture
Core SIEM	Wazuh Manager + Indexer + Dashboard
Primary Targets	Linux hosts, web applications, IoT/network telemetry; Windows/Sysmon extensible
Detection Standard	MITRE ATT&CK + Wazuh rules + Sigma-compatible engineering
Response	SOAR-style playbooks with approval and rollback controls

Prepared as the master product specification derived from the supplied Containerized Attack-Detection Lab proposal.

Document Control & Product Positioning

Area	Decision
Product category	Security Operations / Detection Engineering / DFIR Lab Platform
Primary value	Turn controlled attack activity into telemetry, detections, analyst workflows, response actions and evidence.
MVP basis	Existing Docker + Wazuh + DVWA + monitored-host architecture.
Commercial evolution	Add multi-source ingestion, RBAC, cases, threat intelligence, dashboards, API layer, SOAR controls, reporting, health monitoring and scalable deployment.
Design principle	Detection and operational evidence are the product; exploitation is only the controlled stimulus.
Safety boundary	All offensive activity remains inside explicitly authorized lab/test environments.

Executive Product Statement

SOC Detection Lab is a security operations platform and reproducible cyber range designed to demonstrate, validate and operationalize the full defensive lifecycle: telemetry collection → normalization → detection → alert triage → investigation → threat hunting → containment → recovery → reporting → detection improvement. The initial implementation is deliberately lightweight and zero-cost, while the target architecture is structured so that the same concepts can be evolved into a commercial internal SOC platform, managed security service foundation, or training and validation environment.

Source baseline: The supplied proposal defines a containerized, single-host Wazuh/DVWA lab, ≥8 ATT&CK techniques, ≥80% detection coverage, ≥3 custom rules, a capstone chain, an incident report and a reproducible GitHub repository.

□filecite□turn0file0□L97-L118□

Table of Contents

1. Product Vision and Scope
2. Business & Operational Problem
3. Product Goals and Success Metrics
4. Personas and User Roles
5. Product Capability Map
6. Target Commercial Architecture
7. Data & Telemetry Architecture
8. Detection Engineering
9. Alert Management and Triage
10. Investigation & Threat Hunting
11. Case Management / DFIR
12. SOAR & Response Automation
13. Threat Intelligence
14. Asset, Identity & Risk Context
15. MITRE ATT&CK Coverage
16. Dashboards & SOC UX
17. API & Integration Contract
18. Data Model
19. Security Architecture
20. Reliability, Performance & Scalability
21. Deployment & DevSecOps
22. Product Configuration
23. Testing & Validation
24. Acceptance Criteria
25. Commercial Readiness
26. Licensing & Packaging Strategy

- 27. 27. Implementation Roadmap
- 28. 28. Risk Register
- 29. 29. Future Roadmap
- 30. 30. Appendix: Reference Attack-to-Detection Matrix
- 31. 31. Appendix: Suggested Repository Structure

1. Product Vision and Scope

1.1 Vision

Build a professional SOC platform that can ingest security telemetry from controlled lab assets, identify suspicious behavior using deterministic and behavioral detections, enrich alerts with context, guide an analyst through investigation, execute controlled response playbooks, and preserve an auditable evidence trail.

1.2 Product Boundary

Included	Not a Core Product Requirement
Log/telemetry collection	Replacing every enterprise SIEM capability in v1
Detection rules and behavioral analytics	Unbounded ML research without operational value
Alert triage and case management	Offensive tooling outside the isolated environment
Threat hunting and ATT&CK mapping	Unauthorized scanning/exploitation of third-party systems
Controlled automated response	Unreviewed destructive remediation
Evidence and incident reporting	Guaranteed enterprise HA in the single-host MVP
API/integration foundation	Paid cloud dependency for the zero-budget build

1.3 Evolution Path

The product should be developed in three layers:

32. MVP Lab: single-host Docker deployment proving the telemetry → detection → investigation lifecycle.
33. Professional Lab: production-style analyst console, cases, enrichment, threat intelligence, response playbooks, APIs and observability.
34. Commercial Platform: multi-tenant controls, scalable collectors, HA data services, enterprise identity, licensing, supportability and deployment automation.

2. Business & Operational Problem

A generic penetration-testing demonstration proves that an attack can be executed. A SOC product must instead prove that security teams can observe, detect, prioritize, investigate, contain and learn from that activity.

2.1 Core Problems Solved

- Fragmented security telemetry with no unified analyst view.
- High-volume alerts without consistent severity, context or ownership.
- Detection rules that are not mapped to adversary behavior or validated against real events.
- Slow incident reconstruction because evidence is scattered across logs.
- Manual response actions with weak approval and audit controls.
- No repeatable mechanism for measuring detection gaps.
- Weak portfolio/training environments that demonstrate attacks but not SOC operations.

2.2 Product Value

Stakeholder	Value
SOC Analyst	Prioritized alerts, investigation pivots, timelines, evidence and guided playbooks.
Detection Engineer	Rule lifecycle, test data, ATT&CK mapping, validation and tuning.
Incident Responder	Cases, IOC collection, evidence preservation and containment actions.
SOC Manager	Coverage, SLA, MTTD/MTTR, alert quality and analyst workload visibility.
Security Engineer	Telemetry health, integration status, data quality and deployment controls.

Training / Hiring Team	Reproducible attack-to-detection scenarios and measurable analyst outcomes.
------------------------	---

3. Product Goals and Success Metrics

3.1 MVP Definition of Done

Metric	Target
ATT&CK coverage	≥8 executed techniques across ≥4 tactics
Detection coverage	≥80% of executed techniques generate an alert
Custom detections	≥3 documented custom Wazuh/Sigma-style detections
Capstone chain	1 multi-stage chain with 3–4 techniques
Incident report	1 SOC-standard incident report with timeline, IOCs, detection and remediation
Reproducibility	Clean deployment from repository using Docker Compose
Isolation	No lab exposure to real LAN/public internet
Telemetry gate	Known-good test event visible before attack simulation

3.2 Commercial Product KPIs

KPI	Definition	Target Direction
MTTD	Time from source event to actionable alert	Lower
MTTA	Time from alert creation to analyst acknowledgement	Lower
MTTR	Time from confirmed incident to containment	Lower
Detection coverage	Validated ATT&CK techniques with working detections / tested techniques	Higher
False-positive rate	Alerts closed as benign / total alerts	Lower
Alert fidelity	Actionable alerts / total alerts	Higher
Telemetry health	Healthy sources / configured sources	Higher
Playbook success	Successful response runs / attempted runs	Higher
Evidence completeness	Required case evidence present / required evidence	Higher

4. Personas and User Roles

Role	Primary Responsibilities	Key Permissions
SOC L1 Analyst	Monitor, acknowledge, triage, enrich, escalate	Read telemetry; update alerts/cases; execute approved low-risk playbooks
SOC L2 Analyst	Deep investigation, correlation, hunting	Advanced search; pivot; case ownership; response approval within scope
Detection Engineer	Build/test/tune detections	Create/edit/validate rules; ATT&CK mapping; deploy detection versions
Incident Responder	Containment and evidence	Case management; IOC actions; containment playbooks; evidence export

Threat Hunter	Hypothesis-driven hunting	Query telemetry, saved hunts, timeline analysis
SOC Manager	KPIs, queue, SLA and quality	Reports, dashboards, workload, policy approvals
Platform Admin	Users, integrations, infrastructure	RBAC, connectors, health, configuration, deployment
Auditor	Read-only assurance	Read cases, evidence, reports and audit logs

4.1 RBAC Design

Every privileged action must be authorization-checked server-side. UI visibility is not a security boundary. Response actions should additionally support scoped approvals, dual-control for destructive actions, and complete audit records.

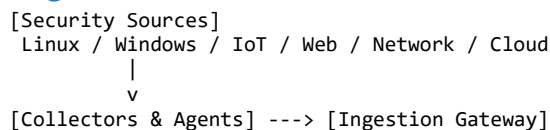
5. Product Capability Map

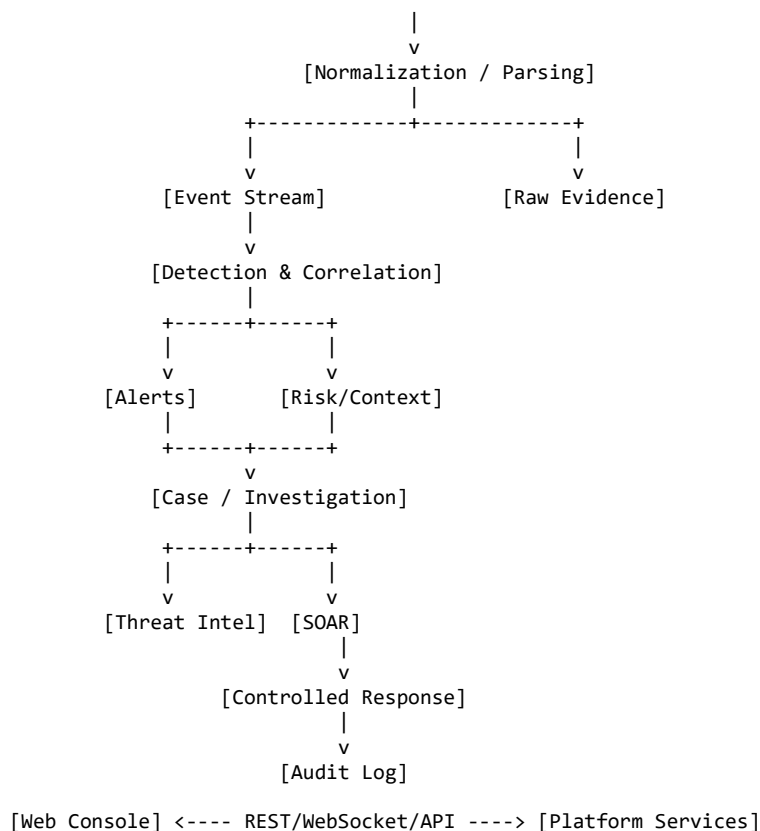
Capability	Scope
Telemetry & Collectors	Wazuh agents, syslog, web logs, auditd, network/PCAP-derived metadata, future Windows/Sysmon and cloud sources.
Normalization	Common event schema, timestamps, source identity, parser status, severity and raw-event preservation.
Detection Engine	Wazuh rules, Sigma-compatible content, correlation, thresholds, sequence detections and behavioral analytics.
Alert Management	Deduplication, suppression, grouping, severity, priority, assignment, SLA and lifecycle.
Investigation	Event pivoting, entity context, timeline, raw evidence, related alerts and IOC extraction.
Threat Hunting	Search, saved queries, hunt notebooks, ATT&CK hypotheses and retrospective validation.
Case Management	Incident records, tasks, evidence, notes, IOCs, timeline, approvals and closure.
SOAR	Playbooks, approval gates, action execution, rollback and audit.
Threat Intelligence	IOC enrichment, reputation context, feed ingestion and confidence scoring.
Asset & Risk	Asset inventory, criticality, exposure, vulnerability context and risk score.
Reporting	Incident reports, executive metrics, coverage reports and audit exports.
Administration	Users, roles, integrations, retention, health, backup and configuration.
Observability	Collector health, ingestion lag, queue depth, rule latency, storage and service health.

6. Target Commercial Architecture

The architecture separates collection, processing, detection, analyst experience and response so that the MVP can grow without redesigning the product.

6.1 Logical Architecture





6.2 Reference Deployment

Layer	MVP	Commercial Target
Orchestration	Docker Compose	Kubernetes / managed containers optional
SIEM	Wazuh Manager/Indexer/Dashboard	Wazuh + platform service layer
Data	OpenSearch/Wazuh index	Hot/warm retention tiers + object/archive storage
API	Wazuh APIs + local scripts	Versioned REST API + WebSocket event channel
Frontend	Wazuh Dashboard	Dedicated SOC analyst console
Automation	Wazuh active response / scripts	Playbook service + approvals + rollback
Identity	Local accounts	OIDC/SAML/LDAP + RBAC + MFA
Observability	Container health	Metrics, logs, traces and SLO dashboards

MVP architecture: The supplied proposal specifies a single-host Docker Compose architecture with Wazuh Manager, Indexer, Dashboard, DVWA, monitored-host containers and an internal Docker bridge network. ☐filecite☐turn0file0☐L139-L170☐

7. Data & Telemetry Architecture

7.1 Supported Initial Sources

- Linux authentication and system logs.
- auditd process/file activity.
- Web server access and error logs.
- DVWA application telemetry.
- Wazuh agent security events.
- Network metadata or future Zeek/Suricata events.

- Controlled PCAP/evidence files for retrospective analysis.

7.2 Event Processing Pipeline

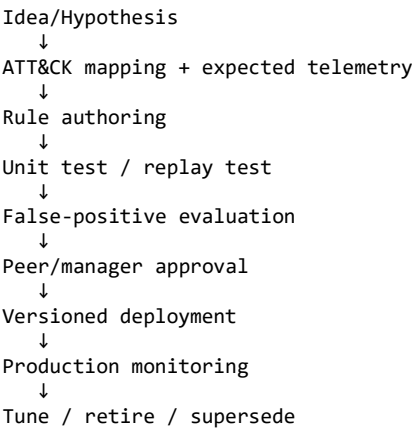
- 35. Collect: acquire event from an approved source.
- 36. Transport: send securely and reliably to ingestion.
- 37. Parse: identify source type and extract structured fields.
- 38. Normalize: map to the platform event schema.
- 39. Enrich: asset, user, ATT&CK, IOC and reputation context.
- 40. Detect: execute atomic, threshold, sequence and behavioral rules.
- 41. Correlate: group related events into an alert/incident hypothesis.
- 42. Persist: retain normalized event plus raw evidence according to retention policy.
- 43. Present: expose to analyst console, API and reports.
- 44. Respond: optionally trigger an approved playbook.

7.3 Data Quality Controls

Control	Requirement
Timestamp	Normalize to UTC internally; retain source timezone where available.
Raw evidence	Preserve original event for forensic verification.
Source identity	Every event must identify source/agent/collector.
Parser status	Malformed or unparsed events must be measurable.
Ingestion lag	Track event_time → indexed_time latency.
Duplicate handling	Provide event fingerprinting or source identifiers.
Retention	Policy-driven hot/warm/archive retention.

8. Detection Engineering

8.1 Detection Content Lifecycle



8.2 Detection Types

Type	Example	Primary Benefit
Atomic	Specific malicious command/payload	High precision for known behavior
Threshold	Repeated authentication failures	Brute-force detection
Sequence	Recon → exploit → credential use	Multi-stage attack visibility
Correlation	Same source hits multiple assets	Campaign-level context
Behavioral	Rare process/network behavior	Unknown/anomalous activity

FIM	Unexpected sensitive file change	Persistence/impact visibility
-----	----------------------------------	-------------------------------

8.3 Rule Metadata Standard

- Unique rule ID and stable name.
- Description and analyst-facing rationale.
- ATT&CK tactic and technique IDs where applicable.
- Severity and confidence.
- Required telemetry source.
- Detection logic and expected fields.
- Known false-positive scenarios.
- Test event / replay fixture.
- Owner, version, created/updated timestamps.
- Rollback/supersession reference.

Source rule standard: The supplied proposal requires each custom rule to document its target technique, ATT&CK ID, why native coverage missed it and the validation command/payload. `filecite``turn0file0``L248-L256`

9. Alert Management and Triage

9.1 Alert Lifecycle

NEW → ACKNOWLEDGED → INVESTIGATING → ESCALATED / CONTAINED → RESOLVED → CLOSED

9.2 Alert Priority Model

Factor	Examples
Severity	Impact represented by detection
Confidence	Detection fidelity / corroboration
Asset criticality	Production-like / high-value target
User risk	Privileged or anomalous identity
Threat context	Known malicious IOC / ATT&CK correlation
Spread	Number of affected assets/users
Recency	Active vs historical

Suggested conceptual score:

$Priority = Severity \times Confidence \times AssetCriticality \times ThreatContext \times SpreadAdjustment$

Important: The score is a prioritization aid, not an automatic verdict. Analysts must be able to see the factors contributing to the score.

10. Investigation & Threat Hunting

10.1 Investigation Workspace

- Alert summary and detection rationale.
- Entity panel: source IP, destination IP, hostname, user, process, asset.
- Event pivot: all related events around the alert.
- Timeline: ordered evidence with relative and absolute timestamps.
- Raw event viewer.
- IOC extraction and enrichment.
- Related alerts and previous activity.
- ATT&CK technique context.

- Analyst notes and evidence attachments.
- One-click escalation to case.

10.2 Threat Hunting Workflow

45. Define hypothesis (e.g., suspicious credential reuse).
46. Identify telemetry needed to prove/disprove it.
47. Run query across a controlled time range.
48. Pivot by entity and timeline.
49. Collect supporting/contradicting evidence.
50. Create detection candidate if repeatable behavior is identified.
51. Record hunt result and detection gap.

11. Case Management / DFIR

11.1 Case Object

Field	Purpose
Case ID	Stable incident identifier
Title / Summary	Human-readable incident description
Severity	Impact classification
Status	Open / Investigating / Contained / Resolved / Closed
Owner	Responsible analyst
Related Alerts	Evidence linkage
Entities	Assets/users/IPs/domains/processes
Timeline	Chronological event narrative
IOCs	Indicators collected during investigation
Evidence	Files/screenshots/raw logs/exports
Tasks	Assigned investigation/remediation actions
Root Cause	Confirmed cause
Lessons Learned	Detection/process improvements
Closure Code	Benign / True Positive / Duplicate / Test / Other

11.2 Evidence Integrity

- Record acquisition timestamp and source.
- Compute a cryptographic hash for exported evidence.
- Preserve original evidence separately from analyst annotations.
- Record who accessed, modified or exported evidence.
- Use immutable/audit-protected storage for finalized case packages where available.

12. SOAR & Response Automation

Response automation must be confidence-aware and reversible. High-impact actions require approval unless an explicit policy grants automatic execution.

Playbook	Trigger	Actions	Approval
PB-01 Brute Force	High-confidence repeated auth failures	Collect evidence → block source in lab → verify → log action	Optional for lab; required for production
PB-02 Web Attack	SQLi/command injection correlation	Enrich IOC → capture context → isolate test target	Recommended

PB-03 Host Quarantine	Confirmed compromise	Disable network access / isolate endpoint → preserve evidence	Required
PB-04 IOC Sweep	Malicious IP/domain/hash	Search historical telemetry → produce impacted asset list	No destructive action
PB-05 Detection Gap	Technique produced no alert	Open detection-engineering task → attach evidence	No

12.1 Safety Controls

- Dry-run mode.
- Approval gate.
- Scope validation: target must belong to an approved environment.
- Idempotency to avoid repeated actions.
- Timeouts and rate limits.
- Rollback action where technically possible.
- Complete action/audit log.
- Kill switch for automation.

13. Threat Intelligence

13.1 IOC Lifecycle

Extract → Normalize → Deduplicate → Enrich → Score → Correlate → Hunt → Case Link → Expire/Retire

13.2 IOC Types

- IPv4/IPv6
- Domain
- URL
- File hash
- Email
- Process/path
- User/account
- Certificate/fingerprint

13.3 Confidence Model

Threat intelligence must expose source, timestamp, confidence and freshness. Intelligence is context, not proof of compromise.

14. Asset, Identity & Risk Context

Object	Core Attributes
Asset	Asset ID, hostname, IP, OS, owner, criticality, environment, telemetry health
Identity	Username, role, privilege level, source, authentication history
Service	Port, protocol, process, exposure, owner
Vulnerability	Identifier, severity, affected asset, remediation status
Risk	Base risk, observed detections, exposure, confidence, last seen

14.1 Risk Context

A low-severity event on a critical asset may require higher priority than a high-severity event on a disposable test asset. The product therefore separates event severity from contextual business risk.

15. MITRE ATT&CK Coverage

Every detection should map to an ATT&CK technique where appropriate. The platform should support coverage reporting at tactic, technique and sub-technique levels, including tested, detected, missed and partially detected states.

State	Meaning
Detected	Executed behavior generated the expected detection.
Partially detected	Some evidence was detected but important context was missing.
Missed	Behavior executed without an actionable detection.
Not tested	No validation evidence exists.
Retired	Detection previously existed but is no longer supported.

16. Dashboards & SOC UX

16.1 Executive Dashboard

- Open incidents
- MTTD/MTTR
- Detection coverage
- Top techniques
- Top assets
- Telemetry health
- Response success
- Alert volume

16.2 Analyst Dashboard

- Priority queue
- Unassigned alerts
- SLA timers
- Recent high-confidence detections
- Investigation shortcuts
- Current incidents

16.3 Detection Engineer Dashboard

- Detection coverage
- Missed-technique queue
- Rule performance
- False-positive rate
- Rule versions
- Validation status

16.4 Required UX Principles

- An analyst should reach raw evidence within two interactions from an alert.
- Every automated action must show why it was triggered.
- Never hide the raw event behind an opaque AI score.
- Critical actions require visible approval state.
- Time, identity and asset context should remain visible during investigation.

17. API & Integration Contract

17.1 API Domains

API Group	Representative Endpoints
Auth	/api/v1/auth/login, /api/v1/auth/refresh
Alerts	/api/v1/alerts, /api/v1/alerts/{id}
Cases	/api/v1/cases, /api/v1/cases/{id}/timeline
Events	/api/v1/events/search
Assets	/api/v1/assets, /api/v1/assets/{id}
Detections	/api/v1/detections, /api/v1/detections/{id}/versions
Hunts	/api/v1/hunts, /api/v1/hunts/{id}/results
Playbooks	/api/v1/playbooks, /api/v1/playbooks/{id}/runs
Threat Intel	/api/v1/intel/iocs, /api/v1/intel/enrich
Reports	/api/v1/reports, /api/v1/reports/{id}/export
Health	/api/v1/health, /api/v1/metrics

17.2 API Requirements

- Versioned endpoints.
- Authentication and authorization on every protected route.
- Request validation and bounded query ranges.
- Pagination for list endpoints.
- Consistent error schema.
- Correlation/request ID.
- Audit logging for mutations.
- Rate limiting for exposed interfaces.

18. Data Model

18.1 Core Entities

Entity	Relationships
Event	belongs to Source/Asset; may trigger Detection
Detection	maps to ATT&CK; generates Alert
Alert	references Events, Assets, Users and IOCs
Case	contains Alerts, Evidence, Tasks, IOCs and Timeline entries
Asset	generates Events and has Risk/Vulnerability context
IOC	linked to Alerts, Cases and Intelligence sources
Playbook	triggered by Alert/Case policy and produces Action Runs
Action Run	belongs to Playbook and Case; creates Audit entries
Audit Event	records administrative or security-sensitive activity

18.2 Wazuh Event Context

The supplied design identifies rule.id, rule.description, rule.level, rule.groups, rule.mitre.id, agent identity, source/destination IP, full_log and timestamp as core investigation fields. These should remain directly accessible in the professional analyst workflow.

❑filecite❑turn0file0❑L235-L247❑

19. Security Architecture

19.1 Secure-by-Design Controls

- Default-deny network boundaries.
- No public exposure for lab services.
- Secrets outside source control.
- Least-privilege containers and service accounts.
- Pinned/reviewed container images.
- Signed or checksum-verified release artifacts where possible.
- RBAC and MFA in commercial deployment.
- Immutable audit logging for sensitive actions.
- Input validation on ingestion and APIs.
- Rate limits and resource quotas.
- Encrypted transport for remote collectors.
- Encrypted storage for sensitive evidence.
- Backup and restore testing.

19.2 Lab Isolation

Source security requirement: The supplied proposal requires internal Docker networking, localhost-only published services, no LAN/public exposure, current images, non-root execution where possible and reset/snapshot discipline. [filecite](#)[turn0file0](#)[L179-L196](#)

20. Reliability, Performance & Scalability

Dimension	MVP Target	Commercial Target
Alert latency	<60s validation gate	Near-real-time; SLO defined per source class
API availability	Best effort	≥99.9% for core API in HA deployment
Data durability	Docker volume backups	Replicated storage + tested backups
Collector health	Manual/container health checks	Automated heartbeat + alerting
Scale	Single host lab	Horizontal collector and processing scale
Retention	Lab-sized	Policy-driven hot/warm/archive
Recovery	Rebuild from compose	Documented RTO/RPO by deployment tier

20.1 Capacity Planning Inputs

- Events/sec
- Average event size
- Peak burst rate
- Retention days
- Search concurrency
- Alert rate
- PCAP volume
- Number of assets
- Number of analysts

21. Deployment & DevSecOps

21.1 Repository-First Delivery

The lab should remain reproducible from source control. The supplied proposal explicitly targets a public repository containing Compose, rules, diagrams, ATT&CK artifacts, reports and README instructions. [filecite](#)[turn0file0](#)[L388-L395](#)

21.2 CI/CD Gates

52. Lint configuration and application code.
53. Validate Docker Compose configuration.
54. Build images and scan dependencies.
55. Run unit tests for parsers, scoring and API validation.
56. Run detection rule syntax tests.
57. Replay known attack fixtures and verify expected alerts.
58. Publish versioned artifacts.
59. Require approval before production response-content deployment.

21.3 Environments

Environment	Purpose
dev	Feature and rule development
test	Detection replay and integration tests
staging	Release candidate validation
lab/prod	Controlled operational deployment

22. Product Configuration

```
config/  
  platform.yaml  
  retention.yaml  
  rbac.yaml  
  detections/  
  playbooks/  
  integrations/  
  assets/  
  threat-intel/
```

22.1 Configuration Principles

- No hard-coded credentials.
- Environment-specific overrides.
- Schema validation before startup.
- Configuration changes versioned and auditable.
- Sensitive values loaded from secrets manager/environment.

23. Testing & Validation

23.1 Test Pyramid

Level	Examples
Unit	Parser, normalizer, risk calculation, API validation
Rule Unit	Individual detection against positive/negative fixtures
Integration	Collector → Wazuh → alert → API
Scenario	End-to-end attack chain
Regression	Previously detected technique after rule change
Security	Auth, RBAC, injection, secret exposure, container hardening
Recovery	Backup restore and lab reset
Performance	Burst event ingestion and alert latency

23.2 Detection Validation Record

Field	Required
Scenario ID	Yes
Technique	Yes
Expected telemetry	Yes
Trigger	Yes
Expected alert	Yes
Observed alert	Yes
False-positive result	Yes
Evidence reference	Yes
Pass/Fail	Yes
Rule version	Yes

24. Acceptance Criteria

- ☐ Clean deployment creates all required services and internal networking.
- ☐ Lab services are not exposed to the real LAN/public internet.
- ☐ A known-good authentication failure reaches the SIEM before attack testing.
- ☐ At least eight ATT&CK techniques are executed in controlled scope.
- ☐ At least 80% of executed techniques generate an actionable alert.
- ☐ At least three custom detections are authored, tested and version-controlled.
- ☐ Every tested technique has detected/missed evidence recorded.
- ☐ The capstone chain can be reconstructed from telemetry without relying on operator memory.
- ☐ An alert can be escalated to a case with timeline and evidence.
- ☐ An approved response playbook can execute a safe containment action and record its audit trail.
- ☐ Detection gaps generate a documented engineering task.
- ☐ A third party can reproduce the MVP from repository instructions.

25. Commercial Readiness

25.1 Productization Gaps from the Current MVP

MVP State	Commercial Requirement
Single operator	Multi-user RBAC, tenant/org boundaries, audit
Wazuh Dashboard-centric	Dedicated analyst UX and API abstraction
Local logs	Remote collectors and secure ingestion
Manual evidence handling	Case/evidence lifecycle and integrity controls
Basic active response	Policy-controlled SOAR with approvals
Static rules	Detection content lifecycle and regression testing
Lab-sized storage	Retention tiers and capacity planning
Local accounts	Enterprise identity integration
Manual reporting	Scheduled and exportable reports

Single host	Scalable/HA deployment profiles
-------------	---------------------------------

25.2 Commercial Quality Bar

- Predictable installation and upgrade process.
- Documented supported versions.
- Health checks and actionable diagnostics.
- Backups and tested restore procedure.
- Security disclosure and patch process.
- Release notes and migration notes.
- API documentation.
- Operational runbooks.
- Customer-facing architecture and security documentation.
- Clear separation between community/open-source components and proprietary platform code.

26. Licensing & Packaging Strategy

The product can be packaged without changing the core lab concept. A practical strategy is to keep the reproducible lab and detection content open where licensing permits, while optional enterprise services provide operational value.

Edition	Target	Features
Community Lab	Students / researchers	Docker deployment, core detections, ATT&CK scenarios, documentation
Professional	Small SOC / training teams	Analyst console, cases, reports, additional integrations, playbooks
Enterprise	Organizations / MSSPs	RBAC/SSO, multi-tenant controls, HA, advanced integrations, support
Managed	Customers without SOC platform staff	Hosted/managed operations subject to deployment/security model

Licensing caution: Before commercial distribution, verify the licenses and redistribution terms of every bundled or referenced third-party component, including Wazuh, OpenSearch, Docker images, detection content and threat-intelligence feeds.

27. Implementation Roadmap

Phase	Duration	Major Deliverables
Phase 0 — Architecture	2–3 days	Repo structure, threat model, network design, service inventory
Phase 1 — Core Lab	Week 1	Wazuh, DVWA, monitored host, telemetry gate, isolation
Phase 2 — Detection	Week 2	8+ ATT&CK techniques, custom rules, detection matrix
Phase 3 — Investigation	Week 3	Timeline, cases, evidence, hunt workflow, capstone
Phase 4 — Response	Week 4	Controlled playbooks, approval, rollback, audit
Phase 5 — Product UX	Weeks 5–6	Dedicated frontend, APIs, RBAC, dashboards
Phase 6 — Intelligence	Weeks 7–8	IOC enrichment, asset risk, reporting
Phase 7 — Commercial Hardening	Weeks 9–12	CI/CD, security testing, observability, packaging, upgrade/backup

27.1 Existing 2–4 Week MVP Alignment

The supplied proposal already defines a four-week path: Week 1 core Wazuh/Docker telemetry, Week 2 technique execution and custom detections, Week 3 capstone reconstruction, and Week 4 reporting/ATT&CK/README publication.

□filecite□turn0file0□L326-L377□

28. Risk Register

Risk	Impact	Mitigation
Telemetry silently fails	Critical	Hard telemetry gate, health monitoring and heartbeat alerts
Container escape / host compromise	Critical	Isolation, patching, non-root, minimal privileges, dedicated host
False-positive overload	High	Rule testing, suppression, confidence, tuning metrics
Indexer resource exhaustion	High	Capacity limits, retention policy, resource monitoring
Automation causes wrong containment	Critical	Approval, scope checks, dry-run, rollback, kill switch
Sensitive evidence leakage	High	Access control, encryption, retention and export auditing
Scope creep	Medium	Phase gates and explicit MVP boundary
Product becomes offense-focused	High	Measure detection, investigation, response and reporting outcomes

Source risks: The original proposal highlights silent agent failure, container escape, alert fatigue, resource exhaustion, scope creep and the risk of the project reading as offensive rather than defensive. □filecite□turn0file0□L396-L433□

29. Future Roadmap

- Windows/Sysmon telemetry.
- OWASP Juice Shop as a second application target.
- Zeek and Suricata network telemetry.
- IoT-specific protocol telemetry and device profiling.
- Behavioral anomaly detection.
- Automated ATT&CK coverage scoring.
- Detection-as-code CI pipeline.
- Advanced case collaboration.
- Threat-intelligence feed connectors.
- Identity provider integration and MFA.
- Multi-tenant MSSP architecture.
- High availability and disaster recovery.
- Cloud and Kubernetes telemetry.
- Purple-team validation and continuous control testing.

Source roadmap: The supplied proposal explicitly identifies Windows/Sysmon, Juice Shop, SOAR-style response and a purple-team retrospective as post-MVP extensions. □filecite□turn0file0□L434-L444□

30. Appendix A — Reference Attack-to-Detection Matrix

Tactic	Technique / Scenario	Telemetry	Detection	Evidence
Recon	Port scanning	Network/web logs	Rate/scan rule	Source IP + target ports

Recon	Directory discovery	Web access log	Request pattern/rate	URI timeline
Recon	Technology fingerprinting	Web/error logs	Pattern rule	Headers/status codes
Initial Access	SQL injection	DVWA access/error	Payload-pattern rule	Raw request + alert
Credential Access	Brute force	Auth logs	Frequency rule	Failed-login sequence
Valid Accounts	Credential reuse	SSH/auth logs	Cross-source correlation	Source/user timeline
Execution	Command injection	auditd/process	Suspicious child process rule	Command/process event
Exfiltration	Controlled data staging	FIM/web/file logs	Unusual file/access pattern	File/event evidence
Impact	Simulated access/impact	Application/system logs	Scenario-specific rule	Case timeline

Source scenario: The supplied proposal's capstone chain uses recon, SQL injection, credential reuse/brute force, command execution and documented impact without live destructive impact. ☐filecite☐turn0file0☐L317-L325☐

31. Appendix B — Suggested Repository Structure

```
soc-detection-lab/
├── docker-compose.yml
├── .env.example
├── README.md
├── LICENSE
├── docs/
│   ├── product/
│   ├── architecture/
│   ├── runbooks/
│   ├── incident-reports/
│   └── threat-model/
├── infrastructure/
│   ├── docker/
│   ├── k8s/
│   └── scripts/
├── detections/
│   ├── wazuh/
│   ├── sigma/
│   ├── tests/
│   └── fixtures/
├── playbooks/
│   ├── brute-force/
│   ├── web-attack/
│   ├── quarantine/
│   └── ioc-sweep/
├── collectors/
├── parsers/
├── api/
├── backend/
│   ├── alerts/
│   ├── cases/
│   ├── hunting/
│   ├── assets/
│   ├── intelligence/
│   └── reporting/
├── frontend/
├── scenarios/
│   ├── dvwa/
│   └── monitored-host/
├── evidence/
│   ├── fixtures/
│   └── exports/
├── tests/
│   ├── unit/
│   ├── integration/
│   ├── security/
│   └── end-to-end/
```

31.1 Engineering Rule

No detection should exist only as an undocumented command or dashboard screenshot. Every important detection must have source-controlled logic, ATT&CK mapping, test evidence, expected telemetry, known false positives and a version.

PRODUCT NORTH STAR

A successful build is not measured by how many attacks the lab can launch. It is measured by how reliably the platform can turn adversary behavior into trustworthy telemetry, high-fidelity detections, explainable analyst decisions, controlled response and auditable evidence.

End of Product Document — Version 1.0